

Module 3: The MITRE ATT&CK Framework

What is MITRE ATT&CK?

MITRE ATT&CK (Adversarial Tactics, Techniques, and Common Knowledge) is a knowledge base of attacker behavior, maintained by the non-profit MITRE Corporation. It is built from observations of actual attacks by nation-state actors, criminal groups, and red teams.

Where the Kill Chain gives you a linear progression, ATT&CK gives you a detailed catalogue of *what specifically attackers do at each stage*.

Reference: <https://attack.mitre.org/>

Structure: Tactics, Techniques, Sub-techniques

Tactics (the "Why")

A **tactic** is a category of attacker goals - *why* an adversary takes an action. ATT&CK for Enterprise has 14 tactics:

ID	Tactic	Description
TA0043	Reconnaissance	Gather information before attacking
TA0042	Resource Development	Acquire or prepare infrastructure, tools, credentials
TA0001	Initial Access	Get a foothold into the target environment
TA0002	Execution	Run malicious code on the target system
TA0003	Persistence	Maintain access across reboots, logouts, credential changes
TA0004	Privilege Escalation	Gain higher-level permissions
TA0005	Defense Evasion	Avoid detection or analysis
TA0006	Credential Access	Steal credentials
TA0007	Discovery	Learn about the environment from within
TA0008	Lateral Movement	Move from one system to another
TA0009	Collection	Gather data of interest
TA0011	Command and Control	Communicate with compromised systems
TA0010	Exfiltration	Transfer data out of the target environment
TA0040	Impact	Disrupt availability or integrity

Techniques (the "How")

A **technique** is a specific method for achieving a tactic. Each technique has a unique ID (e.g., **T1046**). A single tactic has many techniques.

Example: to achieve **Discovery (TA0007)**, an attacker might use:

- **T1046** - Network Service Discovery (scan for open ports)
- **T1082** - System Information Discovery (run `hostname`, `uname`, `id`)
- **T1087** - Account Discovery (read `/etc/passwd`)

Sub-techniques (More Specific Variants)

Some techniques have **sub-techniques** (e.g., **T1098.004** is "Account Manipulation: SSH Authorized Keys"). Sub-techniques share the parent technique ID plus a three-digit suffix.

ATT&CK vs. the Kill Chain

Property	Kill Chain	ATT&CK
Structure	7 linear phases	14 tactic categories (non-linear matrix)
Granularity	Phase-level	Technique-level (hundreds of entries)
Origin	Lockheed Martin, 2011	MITRE, evolving from 2013

The two frameworks are complementary. Use the Kill Chain to explain the *flow* of an attack to stakeholders. Use ATT&CK to precisely name techniques, link to detection logic, and compare to known threat actor behavior.

Technique Mappings for Today's Lab

The table below maps steps we have used to a MITRE ATT&CK technique. Use this as a reference when documenting your attack chain.

Reconnaissance (TA0043)

Technique ID	Name	What We Do
T1595.002	Active Scanning: Vulnerability Scanning	<code>nmap -sV</code> to fingerprint services
T1046	Network Service Discovery	<code>nmap</code> port scan

Initial Access (TA0001)

Technique ID	Name	What We Do
T1190	Exploit Public-Facing Application	vsftpd CVE-2011-2523, Samba CVE-2007-2447, PHP-CGI CVE-2012-1823

Technique ID	Name	What We Do
T1078.003	Valid Accounts: Local Accounts	SSH login with msfadmin/msfadmin

Execution (TA0002)

Technique ID	Name	What We Do
T1059.004	Command and Scripting Interpreter: Unix Shell	Commands run via shell sessions
T1203	Exploitation for Client Execution	Exploit triggers code execution on target

Persistence (TA0003)

Technique ID	Name	What We Do
T1098.004	Account Manipulation: SSH Authorized Keys	Upload SSH public key to <code>~/.ssh/authorized_keys</code>
T1053.003	Scheduled Task/Job: Cron	Write a backdoor cron entry
T1136.001	Create Account: Local Account	<code>useradd</code> to create a backdoor user

Privilege Escalation (TA0004)

Technique ID	Name	What We Do
T1068	Exploitation for Privilege Escalation	vsftpd and Samba exploits already give root directly

Discovery (TA0007)

Technique ID	Name	What We Do
T1082	System Information Discovery	<code>sysinfo, hostname, uname -a, id</code>
T1087.001	Account Discovery: Local Account	<code>cat /etc/passwd</code>
T1057	Process Discovery	<code>ps aux</code>
T1049	System Network Connections Discovery	<code>netstat -an, ss -tn</code>

Collection (TA0009)

Technique ID	Name	What We Do
--------------	------	------------

Technique ID	Name	What We Do
T1005	Data from Local System	Find and read files on the target
T1083	File and Directory Discovery	<code>find / -name "*.conf" -readable</code>

Credential Access (TA0006)

Technique ID	Name	What We Do
T1003.008	OS Credential Dumping: /etc/passwd and /etc/shadow	<code>cat /etc/shadow</code> when root

Command and Control (TA0011)

Technique ID	Name	What We Do
T1095	Non-Application Layer Protocol	Meterpreter TCP channel
T1071.002	Application Layer Protocol: File Transfer Protocols	Sliver beacon (HTTPS)
T1105	Ingress Tool Transfer	<code>webserv</code> + download payload on target

Exfiltration (TA0010)

Technique ID	Name	What We Do
T1041	Exfiltration Over C2 Channel	Meterpreter <code>download</code> command
T1048.003	Exfiltration Over Alternative Protocol: Unencrypted	SFTP download, <code>nc</code> file transfer

Reading the ATT&CK Navigator

The [ATT&CK Navigator](#) is a web-based tool for visualizing technique coverage on the full ATT&CK matrix. You can:

- Highlight which techniques you used in an engagement
- Color-code by detection coverage
- Export views as SVG or Excel for reports

To use it:

1. Open the Navigator
2. Select "Enterprise ATT&CK"

3. Use "Layer Controls" to add annotations
4. Use technique IDs from the table above to find and highlight today's techniques

Annotating Playbook Commands with ATT&CK Metadata

Every AttackMate command supports an optional `metadata` field: a free-form dictionary of key-value pairs that is logged alongside the command but has no effect on execution. This makes it straightforward to tag each step with the ATT&CK tactic and technique it represents, so that log output can be parsed, filtered, or ingested into a SIEM (Security Information and Event Management) after the fact.

How it works

When a command with `metadata` runs, AttackMate writes a line to its log:

```
INFO Metadata: {"tactic": "TA0007", "technique": "T1046",  
"technique_name": "Network Service Discovery"}
```

This line appears in the standard log output and in the JSON audit log (if enabled). The keys are arbitrary; use whatever naming convention your analysis pipeline expects.

Example: annotating a port scan

```
- type: shell  
cmd: nmap -sV -p 21,22,80,443 $TARGET  
metadata:  
  tactic: "TA0007"  
  tactic_name: "Discovery"  
  technique: "T1046"  
  technique_name: "Network Service Discovery"
```

Why this matters for log analysis

If you run a full attack playbook with metadata annotations, the log becomes a structured timeline of ATT&CK-mapped activity. You can then:

- **Grep for all technique IDs** to produce an engagement summary: `grep "Metadata:" attackmate.log | jq .`
- **Filter by tactic** to see only, for example, all Discovery steps
- **Import the log into a SIEM** and correlate AttackMate's ground truth against what the SIEM detected, showing which techniques were visible and which were missed

The metadata field accepts any keys, so you can also add engagement-specific annotations like `operator`, `phase`, `target_host`, or `note` alongside the ATT&CK IDs.

Further Reading

- [MITRE ATT&CK](#) - full technique database
- [ATT&CK Navigator](#) - visualization tool
- [D3FEND](#) - MITRE's companion knowledge base of defensive countermeasures, mapped to ATT&CK